

RAPPORT D'AUDIT – PRÉSENTATION AU BOARD DE DIRECTION

Étape 1 – Mise en place de l'Infrastructure Kubernetes Sécurisée

- **Projet** : Plateforme de Traitement de Commandes
- **Date** : 4 décembre 2025
- **Groupe** : 1067709

1. Synthèse Exécutive (Non-Technique)

Objectif du Projet

L'équipe SecOps a été mandatée pour **auditer et sécuriser** la nouvelle plateforme de traitement de commandes (architecture microservices) avant sa mise en production.

- **Enjeu** : Gérer plusieurs milliers de transactions par jour.
- **Exigences** : Fiabilité, sécurité, et conformité élevées.

2. Principaux Risques Identifiés (État Initial) ● Risques Critiques

- **Risque 1 – Sécurité insuffisante des conteneurs**
 - **Impact** : Accès potentiel total à la plateforme par un attaquant.
 - **Probabilité** : Élevée (déploiement root sans barrière).
 - **Coût potentiel** : 50 000 € à 200 000 € par incident.
- **Risque 2 – Absence d'isolation réseau**
 - **Impact** : Propagation instantanée d'une intrusion (arrêt complet en cascade).
 - **Probabilité** : Élevée (configuration par défaut).
- **Risque 3 – Secrets stockés en clair**
 - **Impact** : Fuite de données sensibles.
 - **Coût potentiel** : >100 000 € (sanctions RGPD + remédiation).

● Risques Moyens

- **Risque 4** : Absence de scan de vulnérabilités.
- **Risque 5** : Droits d'accès trop larges (violation du moindre privilège).

3. Avancement – Étape 1 Terminée : Fondations Opérationnelles ✓ Réalisations Majeures

- Déploiement d'un cluster Kubernetes haute disponibilité (3 serveurs).
- Mise en place d'un monitoring complet (Prometheus + Grafana).
- Installation d'une file de messages robuste (RabbitMQ + Dead Letter Queue).
- Mise en place des outils de sécurité (Kyverno, Trivy, Cosign) – *en attente d'activation*.

- Déploiement automatisé et reproductible.

Indicateurs de Performance (Étape 1)

Métrique	Objectif	Résultat
Disponibilité plateforme	> 99%	100%
Temps de réponse API	< 200 ms	< 100 ms
Monitoring temps réel	Oui	Actif

4. Plan d'Action Sécurité (Étapes 2 à 6 – Décembre 2025)

Période	Étape	Thème	Bénéfice Clé
6 → 9 déc.	Étape 2	Verrouillage des conteneurs (Activation des politiques, Scan Trivy)	Réduction de 80 % des surfaces d'attaque.
10 → 12 déc.	Étape 3	Isolation réseau et contrôle d'accès (Pare-feu interne)	Empêche la propagation latérale en cas d'intrusion.
13 → 15 déc.	Étape 4	Chiffrement et gestion des secrets	Conformité RGPD garantie (zéro secret exposé).
16 → 19 déc.	Étape 5	Résilience et Haute Disponibilité (Autoscaling KEDA)	Plateforme capable d'absorber ×5 le pic de charge.
20 → 22 déc.	Étape 6	Validation finale (Tests d'intrusion)	Certification de sécurité (prêt pour la production).

5. Impact Financier et ROI

Risque Évité	Coût Potentiel	Probabilité (sans action)
Incident sécurité majeur	50 000 – 200 000 €	60%
Amende RGPD	>100 000 €	30%
Interruption plateforme	10 000 €/h	40%

- **Coût d'investissement** : Environ 44 heures d'équipe SecOps (aucun coût logiciel).

- **ROI global estimé : 150 000 € à 400 000 € économisés** sur 12 mois.

6. Décisions Demandées au Board Décision 1 – Mode d’application des politiques sécurité

Option	Avantages	Inconvénients	Recommandation
Option A : Mode Strict	Sécurité maximale, Conformité garantie	Nécessite sensibilisation des équipes	RECOMMANDÉ
Option B : Mode Alerte	Transition en douceur	Sécurité dégradée, Risque de régression	

Décision 2 – Date de go-live

1. **Option 1 : Après Étape 6 (22 décembre)**
2. **Option 2 : Après Étape 4 (15 décembre) – Risqué**
 - **Recommandation** : Option 1 (attendre la validation complète).

7. Conclusion

- **Statut Actuel** : Infrastructure stable, surveillée et reproductible. Outils de sécurité prêts à l’emploi.
- **Risques Actifs (en attente des étapes 2-6)** : Politiques de sécurité non activées, Secrets non chiffrés, Flux réseau non cloisonnés.
- **Prochaine Revue Board** : **12 décembre 2025** (point d’étape après l’Étape 3).